

INFORME TÉCNICO DE INCIDENTE DE SEGURIDAD

Fecha: 07/01/2026 Analista: Samuel Perez Asunto: Recuperación, Análisis Forense y Hardening de Servidor Debian Comprometido1.

Resumen Ejecutivo

Se ha realizado una intervención de emergencia en el servidor crítico de la organización tras detectarse una pérdida de disponibilidad y posibles accesos no autorizados. El objetivo de la misión ha sido recuperar el control administrativo (root), identificar las vulnerabilidades explotadas y asegurar el sistema para prevenir futuros ataques.

El servidor se encuentra actualmente operativo, actualizado y con las medidas de seguridad reforzadas (Hardening) aplicadas según los estándares de la industria.

2. Recuperación de Acceso (Forense Inicial)

Al inicio de la intervención, se constató la pérdida total de credenciales administrativas. Para recuperar el control del activo sin dañar la integridad de los datos, se procedió a una intervención física en el arranque.

Procedimiento Técnico: Se interceptó el gestor de arranque GRUB para modificar los parámetros del Kernel de Linux. Se alteró la instrucción de

```
GNU GRUB  version 2.06-13+deb12u1

setparams 'Debian GNU/Linux'

load_video
insmod gzio
if [ x$grub_platform = xxen ]; then insmod xzio; insmod lzopio; fi
insmod part_msdos
insmod ext2
set root='hd0,msdos1'
if [ x$feature_platform_search_hint = xy ]; then
  search --no-floppy --fs-uuid --set=root --hint-bios=hd0,msdos1 --hint-efi=hd0,msdo\
s1 --hint-baremetal=ahci0,msdos1  e477ca65-16ff-4c7b-b4c5-9c1649306070
else
  search --no-floppy --fs-uuid --set=root e477ca65-16ff-4c7b-b4c5-9c1649306070
fi
echo          'Loading Linux 6.1.0-25-amd64 ...'
linux        /boot/vmlinuz-6.1.0-25-amd64 root=UUID=e477ca65-16ff-4c7b-b4c5-9c164930\
6070 rw quiet init=/bin/bash splash speakup.synth=none
echo          'Loading initial ramdisk ...'
initrd       /boot/initrd.img-6.1.0-25-amd64

Minimum Emacs-like screen editing is supported. TAB lists completions. Press Ctrl-x
or F10 to boot, Ctrl-c or F2 for a command-line or ESC to discard edits and return
to the GRUB menu.
```

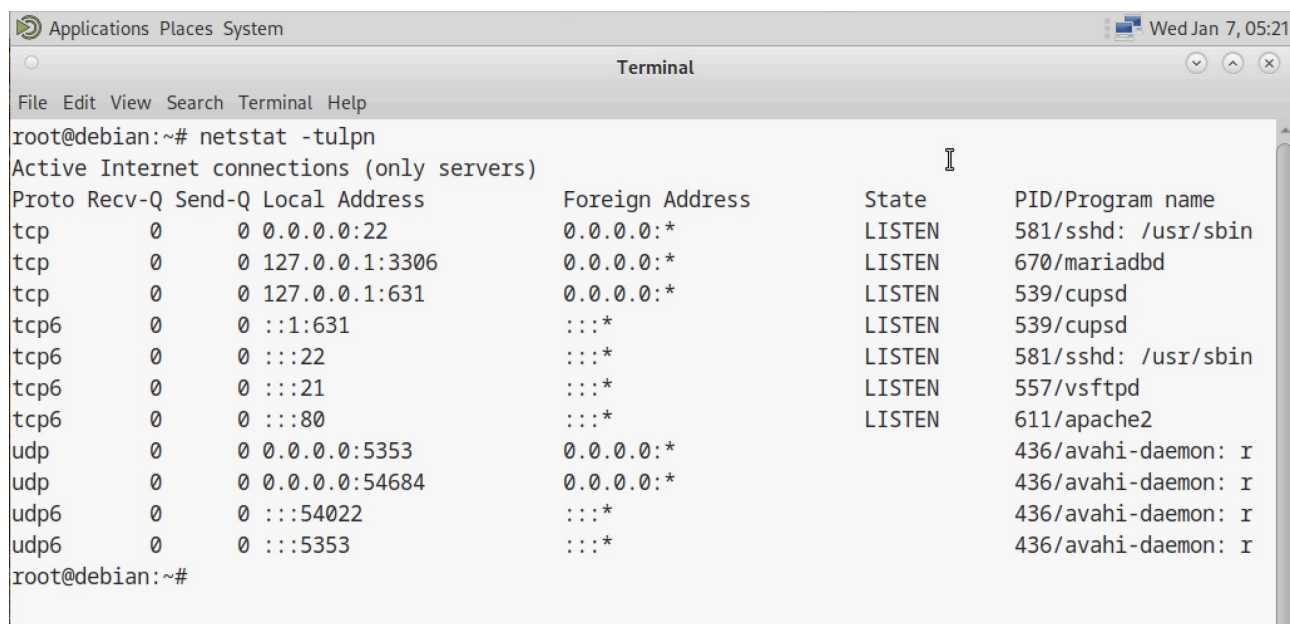
© debian 12

arranque cambiando el modo de "solo lectura" (ro) a "lectura-escritura" (rw) y forzando la ejecución de una shell de sistema (init=/bin/bash) antes de la carga

```
done.
Begin: Mounting root file system ... Begin: Running /scripts/local-top ... done.
Begin: Running /scripts/local-premount ... done.
Begin: Will now check root file system ... fsck from util-linux 2.38.1
[/sbin/fsck.ext4 (1) -- /dev/sda1 fsck.ext4 -a -C0 /dev/sda1
/dev/sda1: recovering journal
/dev/sda1: clean, 189363/1925120 files, 1762058/7688960 blocks
done.
[ 12.383686] EXT4-fs (sda1): mounted filesystem with ordered data mode. Quota mode: none.
done.
Begin: Running /scripts/local-bottom ... done.
Begin: Running /scripts/init-bottom ... done.
bash: cannot set terminal process group (-1): Inappropriate ioctl for device
bash: no job control in this shell
root@(none):/# passwd
New password:
Retype new password:
passwd: password updated successfully
root@(none):/# _
```

de la interfaz gráfica.

Evidencia de la intervención:



```
Applications Places System
Terminal
File Edit View Search Terminal Help
root@debian:~# netstat -tulpn
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      581/sshd: /usr/sbin
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      670/mariadb
tcp        0      0 127.0.0.1:631          0.0.0.0:*               LISTEN      539/cupsd
tcp6       0      0 :::1:631                :::*                   LISTEN      539/cupsd
tcp6       0      0 :::22                  :::*                   LISTEN      581/sshd: /usr/sbin
tcp6       0      0 :::21                   :::*                   LISTEN      557/vsftpd
tcp6       0      0 :::80                   :::*                   LISTEN      611/apache2
udp        0      0 0.0.0.0:5353            0.0.0.0:*               *          436/avahi-daemon: r
udp        0      0 0.0.0.0:54684           0.0.0.0:*               *          436/avahi-daemon: r
udp6       0      0 :::54022                :::*                   *          436/avahi-daemon: r
udp6       0      0 :::5353                 :::*                   *          436/avahi-daemon: r
root@debian:~#
```

Una vez obtenida la shell de root, se procedió al restablecimiento de la contraseña del superusuario, recuperando así el control total del sistema.

```
root@debian:~# grep "anonymous_enable" /etc/vsftpd.conf
anonymous_enable=YES
root@debian:~#
```

3. Análisis de Superficie de Ataque

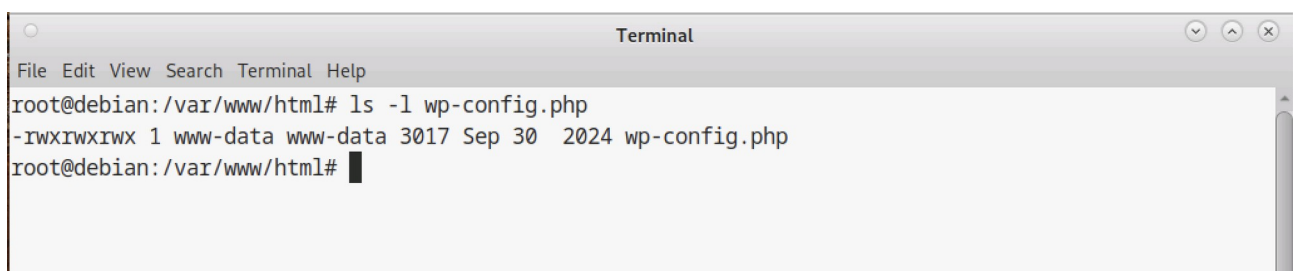
Con el acceso recuperado, se realizó un escaneo interno de puertos y servicios para identificar qué puertos dejó abiertas el atacante.

Herramientas utilizadas: netstat, ss.

Se observan activos: FTP (21), SSH (22), HTTP (80) y MySQL (3306).

4. Hallazgos de Vulnerabilidades y Medidas Correctivas

Durante la auditoría forense se detectaron múltiples configuraciones inseguras

A terminal window titled "Terminal" with a menu bar (File, Edit, View, Search, Terminal, Help). The prompt is root@debian:/var/www/html#. The command ls -l wp-config.php is entered, and the output is -rwxrwxrwx 1 www-data www-data 3017 Sep 30 2024 wp-config.php. The prompt is then root@debian:/var/www/html#.

```
root@debian:/var/www/html# ls -l wp-config.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30 2024 wp-config.php
root@debian:/var/www/html#
```

que comprometían la confidencialidad e integridad del servidor. A continuación, se detallan los hallazgos y las soluciones aplicadas.

4.1. Servicio FTP Inseguro (Puerto 21)

Vulnerabilidad: El servicio vsftpd estaba configurado para permitir el acceso a usuarios anónimos (sin contraseña), permitiendo la exfiltración de datos.

Evidencia:

Configuración crítica permitiendo acceso anónimo.

Acción Correctiva: Se modificó /etc/vsftpd.conf estableciendo anonymous_enable=NO y se reinició el servicio.

```
root@debian:~# cat /var/www/html/wp-config.php | grep "DB_PASSWORD"
define( 'DB_PASSWORD', '123456' );
root@debian:~# mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 10.11.6-MariaDB-0+deb12u1 Debian 12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

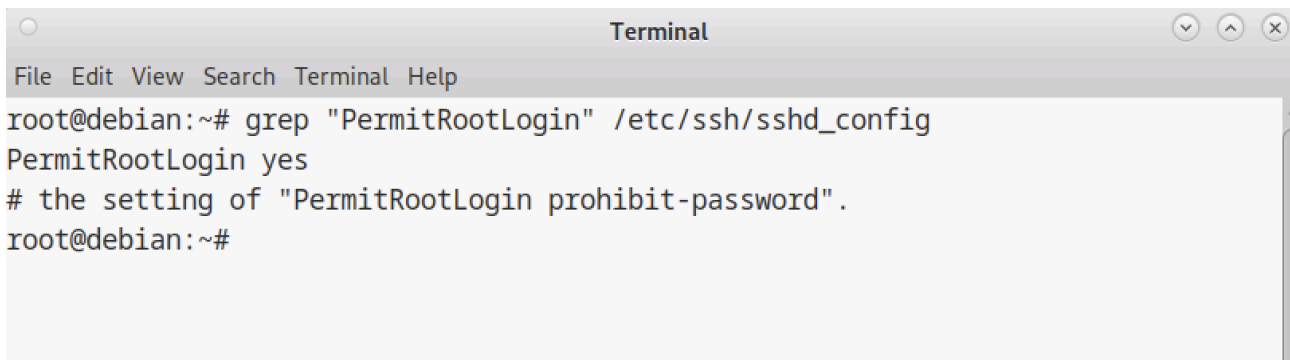
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> █
```

4.2. Exposición de Archivos Críticos Web (Puerto 80)

Vulnerabilidad 1 (Permisos): El archivo de configuración de WordPress wp-config.php, que contiene claves de base de datos, tenía permisos 777 (lectura global).

Vulnerabilidad 2 (Credenciales): Dentro de dicho archivo, se identificó el uso de contraseñas débiles/por defecto para la base de datos.



```
Terminal
File Edit View Search Terminal Help
root@debian:~# grep "PermitRootLogin" /etc/ssh/sshd_config
PermitRootLogin yes
# the setting of "PermitRootLogin prohibit-password".
root@debian:~#
```

Evidencia:

Permisos inseguros en archivo de configuración.

Exposición de credenciales en texto plano.

Acción Correctiva: Se aplicó el comando `chmod 600 wp-config.php` restringiendo la lectura únicamente al propietario (root).

4.3. Configuración SSH Débil (Puerto 22)

Vulnerabilidad: El servicio SSH permitía el inicio de sesión directo como usuario root, lo que facilita ataques de fuerza bruta.

Evidencia:

Política de acceso remoto insegura.

Acción Correctiva: Se editó `/etc/ssh/sshd_config` cambiando el parámetro `PermitRootLogin` a `no`. Se recomienda el uso de usuarios nominales y escalado de privilegios mediante `sudo`.

5. Conclusiones y Recomendaciones (Fase 3)

El servidor ha sido estabilizado. Se han cerrado los vectores de ataque principales (FTP anónimo, Web Listing, SSH Root).

Recomendaciones finales para la gerencia:

Implementación de Firewall: Activar `ufw` para filtrar tráfico no deseado.

Política de Contraseñas: Obligar a la rotación de claves de base de datos cada 90 días.

Monitoreo: Centralizar los logs de `/var/log/auth.log` en un servidor externo para evitar manipulación de evidencias.